

Security Audit — Play It Safe: Manage Security Risks

Activity Context

This activity involved conducting an internal security audit for a fictional small business (Botium Toys, a U.S. toy company expanding into online and international sales). The scenario centered on their IT manager needing to assess security posture and compliance ahead of continued growth, including handling online payments and doing business in the E.U. I reviewed the company's stated assets and risk assessment notes, then completed a controls and compliance checklist covering relevant security control categories, using the NIST Cybersecurity Framework as a reference point.

Controls & Compliance Checklist

The completed checklist is saved in this same folder as "Controls-and-Compliance-Checklist.pdf"; viewers can open it directly from this repository.

Findings Summary

The audit revealed that Botium Toys' current security posture has several notable gaps, particularly around access control and data protection. Controls such as least privilege and separation of duties were not consistently applied, meaning more people likely have access to sensitive systems than their roles require a common but serious risk as a company scales. The absence of encryption and a formal password management system also stood out, especially given the company's growing exposure to online payments and international customers. Taken together, these gaps suggest Botium Toys' security controls haven't kept pace with its business growth, which is exactly the kind of disconnect an internal audit is meant to catch early.

Recommendations

Based on these findings, I'd prioritize three things first: enforcing least privilege and separation of duties to limit unnecessary access, implementing encryption to protect sensitive data (particularly payment information), and establishing a disaster recovery plan so the company can respond effectively if an incident does occur. Ongoing legacy system management and a proper password policy would follow as the next layer of improvement.

Key Concepts This Reinforced

- ✓ Frameworks like NIST CSF give structure to an audit, so findings aren't just opinions but tied to recognized standards
- ✓ A company's risk exposure changes as it grows, Botium Toys' shift toward online and international sales introduced compliance concerns (like E.U. regulations) that didn't exist when they were a single physical storefront
- ✓ An audit's value isn't just the checklist itself, but translating "no" answers into concrete recommendations a business can act on